

Danmarks
Tekniske
Universitet



Misuse of DTU Computer Server Runbook

GROUP 4

Metehan Gelgi - s232839
Yashasvi Tirpur Vishwanath - s242563
Stefano Licinio - s232450
Dodzi Kwasi Nuhoho - s240054

September 5, 2026

Contents

1	Introduction	1
2	Preparation	1
2.1	Roles and Responsibilities	1
2.2	Activation of Runbook	1
2.3	Identify Critical Assets	2
2.4	Legal and Policy Review	2
2.5	User Access Controls Management	3
3	Detection	3
3.1	Receive Notification and Initial Steps	3
3.2	Collect Relevant Data and Logs	4
3.3	Preserve and Document Evidence	4
4	Verify	4
4.1	Initial Validation	5
4.2	Logs and Technical Validation	5
4.3	False positive checks	5
4.4	Policy and Legal Assessment	5
4.5	Documentation	6
5	Assessment and Escalation	6
5.1	Assessment Impact	6
5.2	Criteria for escalation:	7
5.3	Internal and External Escalation Process:	8
6	Containment	9
6.1	Short-Term Containment	9
6.2	Evidence Preservation	9
6.3	Stakeholder Notification	10
7	Eradication	12
7.1	Identify and Remove the Root Cause	12
7.2	Apply Security Fixes	12
7.3	Validate the Environment	12
7.4	Harden the Server	12
8	Recovery	13
9	Post-Incident Activities	14
9.1	Incident report	14
9.2	Lesson learned	14
9.3	Implementation of new preventive measures	15

10 Conclusion	15
References	16

1 Introduction

At DTU Compute, we rely on our servers every day to support research, teaching, and collaboration. These systems help students, staff, and partners across many areas of work. But with that wide use comes responsibility. If someone uses our servers for illegal or harmful purposes, it is not just a technical issue. It can lead to serious consequences for the university and everyone involved.

This runbook outlines the procedures to be followed when DTU Compute is notified regarding a server suspected of being involved in misuse. Misuse in this context refers to illegal or unauthorized activities conducted using DTU Compute server resources. This can include, but is not limited to, activities such as:

- Hosting or distributing illegal content (e.g., child pornography, copyrighted material without permission).
- Involvement in cybercrime activities (e.g., spam campaigns, phishing, denial-of-service attacks, hosting command and control infrastructure).
- Activities potentially linked to serious criminal acts (e.g., terrorism).

This runbook is created based on the guidelines provided by [1, 2, 3], and outlines each stage of the incident response lifecycle, including preparation, detection, verification, assessment, containment, eradication, recovery, and post-incident reflection.

2 Preparation

Preparation step is initial step of runbook in incident response plan. Before an incident occurs, it's important that DTU Compute has the right team, tools, and processes in place. This chapter explains what needs to be ready ahead of time, and who is responsible for it.

2.1 Roles and Responsibilities

This part explains roles and responsibilities regarding to this runbook. Everyone should know who to contact, how to reach them, and what each person is expected to do. Table 1 shows list of roles in context of this runbook.

2.2 Activation of Runbook

The runbook should only be used when a suspicion on serious misuse case is reported or detected. The runbook should be activated by the authorized person only. Nicola Dragoni is responsible for activation of runbook. In first authorized person not available, Gauravn Choudhary and Michael Mozim Michael Gromiha is responsible in order.

Table 1: DTU Compute Misuse of DTU Server (Hypothetical) Contact List

Role	Name	Department	Contact
Head of Section, Cybersecurity Engineering	Nicola Dragoni	DTU Compute	mads.lin@dtu.dk
Associate Professor	Gauravn Choudhary	DTU Compute	gauch@dtu.dk
Runbook Specialist	Michael Mozim Michael Gromiha	DTU Compute	mozim@dtu.dk

2.3 Identify Critical Assets

We need a clear and current list of important servers, services and network topology. This helps us know what is at risk and who is responsible. This list of assets is important for this runbook and other runbooks. Table 2 shows lists of hypothetical assets and owners of the critical assets, as we do not know the details of the DTU Compute Servers.

Table 2: Hypothetical Asset Inventory - DTU Compute Servers

Server Name	IP Address	Owner	Function	Data Type
compute-app1	192.168.10.10	Nicola Dragoni	Research Web Service	Public / Research
storage-core	192.168.10.50	Gauravn Choudhary	File Storage & Backups	Confidential / PII
model-train02	192.168.12.15	Michael Mozim	ML Training for PhD Groups	Sensitive Research
vpn-gw	192.168.11.1	Jan Madsen	VPN Gateway for Staff Access	Credentials / Logs

2.4 Legal and Policy Review

This part focuses on ensuring that all actions taken during an incident follow the applicable Danish laws, DTU internal policies, and ethical standards. Before any incident occurs, it is important to understand the legal requirements and responsibilities of investigating a misuse case.

- All actions taken during an incident must follow Danish laws, DTU internal policies, and ethical standards.
- DTU's internal policies (e.g. IT Security Policy and User Policy for DTU IT Systems) should be developed and distributed internally. These policies should be followed at all times.
- Users of DTU Compute systems must accept the university's user policy before being granted access, and a signed copy should be stored internally.
- The user policy must clearly define acceptable use, prohibited actions, and consequences of violations.

- A checklist of legal escalation triggers must be maintained and reviewed regularly to ensure a timely legal response when required.
 - Serious threats or criminal misuse of infrastructure
 - Child sexual abuse material (CSAM)
 - Terrorism-related content or communication
- The Incident Response Team's documentation must include contact details for DTU Legal and instructions for when and how to consult them.

2.5 User Access Controls Management

This part focuses on user access management for DTU Compute servers. Proper access control is essential to prevent unauthorized use of DTU Compute resources.

- All systems must implement strict access management based on roles and permissions.
- The principle of least privilege must be applied, ensuring users have only the access needed for their specific tasks.
- All access to critical systems must be logged, and user activity should be reviewed regularly.
- All user roles and their associated permissions must be clearly defined and documented.
- Central identity management systems such as LDAP or Active Directory should be used to manage user access securely.
- Two-factor authentication (2FA) or equivalent strong authentication mechanisms must be enforced on all critical systems.

3 Detection

This section focuses on the first steps to take when a possible misuse of a DTU Compute server is reported or detected. The goal is to gather as much reliable and relevant information as possible while preserving evidence for later analysis and possible legal action.

3.1 Receive Notification and Initial Steps

When DTU Compute is informed of possible misuse or identifies suspicious activity through internal monitoring, the first step is to log all key details. This includes:

- Who reported the incident (name, timestamp, or source)
- A description of the suspected misuse or abnormal activity
- Reported systems, users, or services

3.2 Collect Relevant Data and Logs

Investigate the reported activity, collect data related to the affected systems, services, or users.

- Authentication logs (who used server)
- Logs from running services (like web servers or SSH)
- Firewall, IDS/IPS, and router logs
- File systems of suspected servers and file access logs and user session history

Data collection should be performed carefully to avoid overwriting or losing valuable information. Store all logs and data in a secure and centralized location for further analysis.

3.3 Preserve and Document Evidence

Save any evidence showing how the server was misused.

- Screenshots of the system or content
- Suspicious files, scripts, or code
- Changes to server settings or configuration files
- Logs showing user actions or commands

Store the evidence safely. Label it clearly and note how and when it was collected. Keep everything in case legal teams or authorities need it later.

The collected data and evidence will help to decide how serious the incident is and what actions are needed next.

4 Verify

This step involves the confirmation of the reported activity as a legitimate misuse of DTU servers. This involves determining the scope of the incident and evaluating the credibility of the source. The verification of the incidents should be carried out vigilantly to avoid misinterpretation of data or to avoid improper accusations.

4.1 Initial Validation

- Validate the server details including IP address, service name, host name with DTU Compute's asset records to verify the reported system belongs to DTU.
- Confirm that the reported incident is received from a trusted and official source - eg. internal security teams, law enforcement.
- Check timestamps, IP addresses, user identification mentioned in the reported incident.
- Clearly identify the nature of the misuse : child exploitation material, distribution of intellectual property, spam/phishing etc.

4.2 Logs and Technical Validation

- Retrieve and review the logs from the suspected server including system, application, mail logs.
- Identify the activities that match the reported incident (eg. illegal file upload, unauthorized access)
- Analyze logs for suspicious user behavior such as logins from foreign IP's, login attempts at unusual hours.
- Conduct a scan of the server for:
 - Malicious software or unauthorized scripts.
 - Presence of illegal media files or prohibited content.
 - Unauthorized user accounts or privilege escalations.

4.3 False positive checks

- Consider and rule out use cases of the flagged activity that resembles misuse:
 - Academic research project generating unusual traffic.
 - Test environments with dummy data (clearly documented in advance).
 - Misconfigured software generating unusual traffic.

4.4 Policy and Legal Assessment

- Determine if the identified activity violates DTU's Acceptable Use Policy or national/international legal laws.
- For cases involving sensitive cases(eg. child pornography, terrorism) immediately notify DTU's legal team or Data Protection Officer.

4.5 Documentation

- Document and maintain detailed notes of:
 - Systems reviewed, logs accessed, and tools used.
 - Evidence found or lacking.
 - Indicators of compromise.
 - Names of involved personnel in verification and the timestamp of activities
- If confirmed proceed to next step : Assessment and Escalation

Figure 1, visually represents the Verify step.

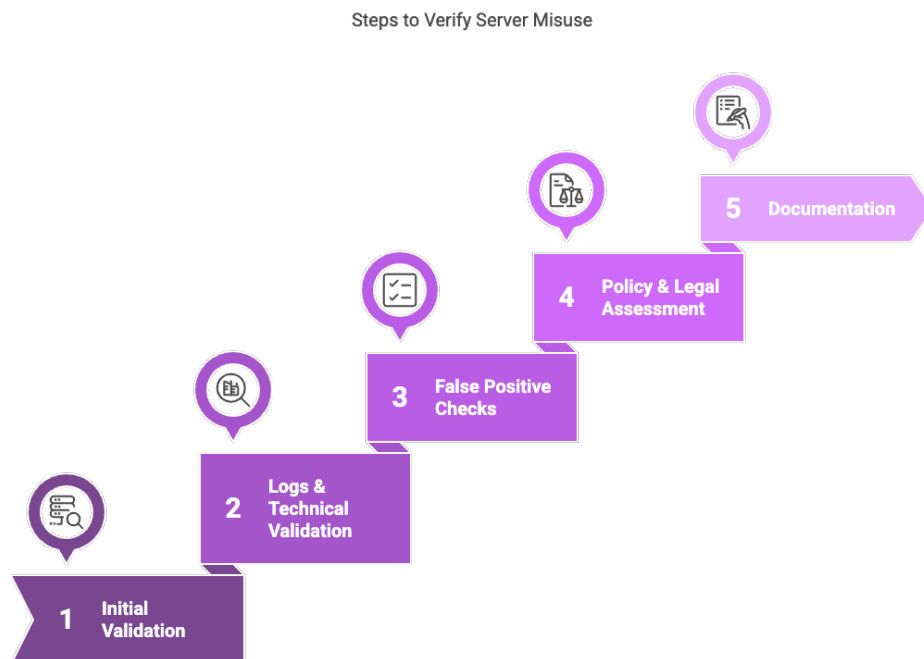


Figure 1: Verify

5 Assessment and Escalation

The main purpose of this step is to identify and assess the severity, scope NS and possible impact of the identified and confirmed incident. It also helps us determine the appropriate action to consider, including escalation to relevant authorities and management if necessary.

5.1 Assessment Impact

- Classification of the severity of the incident:
 - Low:** Limited misuse of the systems with no sensitive data exposure or significant

reputational risk has taken place.

Medium: Misuse involving policy violations, GDPR issues, and significant reputational damage (e.g., phishing, unauthorized access).

High: Serious misuse of the server, which includes terrorism-related activity, child sexual abuse material(CSAM), and illegal distribution of intellectual property.

- Evaluation of the affected systems and data:
 - Identify all the affected systems, servers, services, and DTU systems which has been affected by the misuse. This includes both physical and virtual machines, cloud services, network infrastructure.
 - Determine all the roles and functions of the systems affected by the incident, e.g., research, teaching, administration, databases, and websites.
 - Assess if the affected systems are integrated or isolated with other university infrastructure, which might affect the risk of broader exposure.
 - Clearly examine and identify whether sensitive personal data defined by the GDPR, copyrighted material and illegal or criminal content is involved.
 - Coordinate these decisions with the DTU Data Protection Officer (DPO) and DTU Legal Team and determine whether DTU is required to notify the Danish Data Protection Agency (Datatilsynet) within 72 hours, in accordance with GDPR Article 33.

5.2 Criteria for escalation:

- Criminal Activity: Suspected terrorism and illegal activities under the Danish Penal Code are confirmed.
- Personal Data Involvement: If sensitive personal data has been processed or exposed unlawfully.
- Violation of IP rights: If copyrighted content or intellectual property is distributed without proper authorization, potentially violating the Danish Copyright Act.
- Use of DTU resources: Any use of DTU's resources for prohibited purposes, that violates the DTU's Acceptable Use Policy or Institutional IT security policies (e.g., running spam campaigns, unauthorized external services)

In all such cases, it is mandatory to escalate to the DTU Legal and Compliance Office. The Legal team will coordinate external communications, legal assessments, and compliance with regulatory obligations.

5.3 Internal and External Escalation Process:

- Immediately inform the DTU Compute Security Team and begin evidence preservation.
- Immediately contact DTU Data Protection Officer (DPO) for any incident involving personal data.
- Notify DTU IT Operations Team to prepare for containment or forensic tasks.
- Escalate to university leadership (e.g., CISO, department heads) if the incident affects institutional integrity or media involvement is expected.
- Contact Danish National Police (Politiet) for CSAM or terrorism-related incidents if confirmed by coordinating with the DTU's legal team.
- DTU Legal team will handle all legal communication with law enforcement and regulatory bodies.
- Ensure that chain of custody and confidentiality guidelines are respected in all the above interactions.

Role	Name	Department	Email	Phone Number
Head of Section, Cybersecurity Engineering	Nicola Dragoni	DTU Compute	mads.lin@dtu.dk	+45 4525 3726
Associate Professor	Gauravn Choudhary	DTU Compute	gauch@dtu.dk	+45 4525 3750
Chief Information Security Officer (CISO)	Henrik Larsen	DTU IT	ciso@dtu.dk	+45 4525 0000
Data Protection Officer (DPO)	Mads Mikkelsen	DTU Legal/-Compliance	dpo@dtu.dk	+45 4525 0001
Head of DTU Compute	Jens SparsÅ,	DTU Compute	sparsoe@dtu.dk	+45 4525 3720
Police & Cybercrime Unit (Copenhagen)	Contact Officer	Danish National Police	politi@politi.dk	+45 114
DTU Legal Team Representative	Viktor Axelsen	DTU Legal	legal@dtu.dk	+45 4525 0002

Table 3: Key Contacts for Incident Response - DTU Server Misuse

6 Containment

The objective of this step is to stop the ongoing misuse of the server, prevent further damage, and preserve evidence for investigation afterwards.

6.1 Short-Term Containment

- Isolate the affected server from the network (logically or physically).
- If critical services are hosted, consider:
 - Redirecting traffic to a clean standby server.
 - Suspending only compromised components.
- Disable potentially compromised user or service accounts.
- Revoke or rotate relevant credentials or API tokens
- Block suspicious traffic at the firewall, security group, or gateway
- Suspend unauthorized or abnormal services/processes.
- Continuously monitor the network and the affected server (if partially contained) to verify the effectiveness of the containment measures and detect any attempts by the threat actor to bypass them or adapt their tactics.

6.2 Evidence Preservation

- Capture system memory using trusted acquisition tools appropriate for the operating system and environment.
- Take a snapshot of the disk or full instance for virtual or cloud-based servers.
- For physical servers: perform a full disk image using forensic imaging tools.
- Log and Metadata Collection:
 - Secure and export system logs, authentication logs, application logs, and network activity logs.
 - Record current processes, open connections, user sessions, and active tasks.
 - Store evidence in a secure, read-only location with proper access controls and audit trails.

6.3 Stakeholder Notification

- Notify the responsible internal teams and leaders (Security, IT, Legal, etc.) through designated incident communication channels.
- Update incident records in the organization's tracking or ticketing system
- Document containment actions taken and current system status

For visual representation, take a look at Fig2 for an overview.

Containment and Evidence Preservation Process

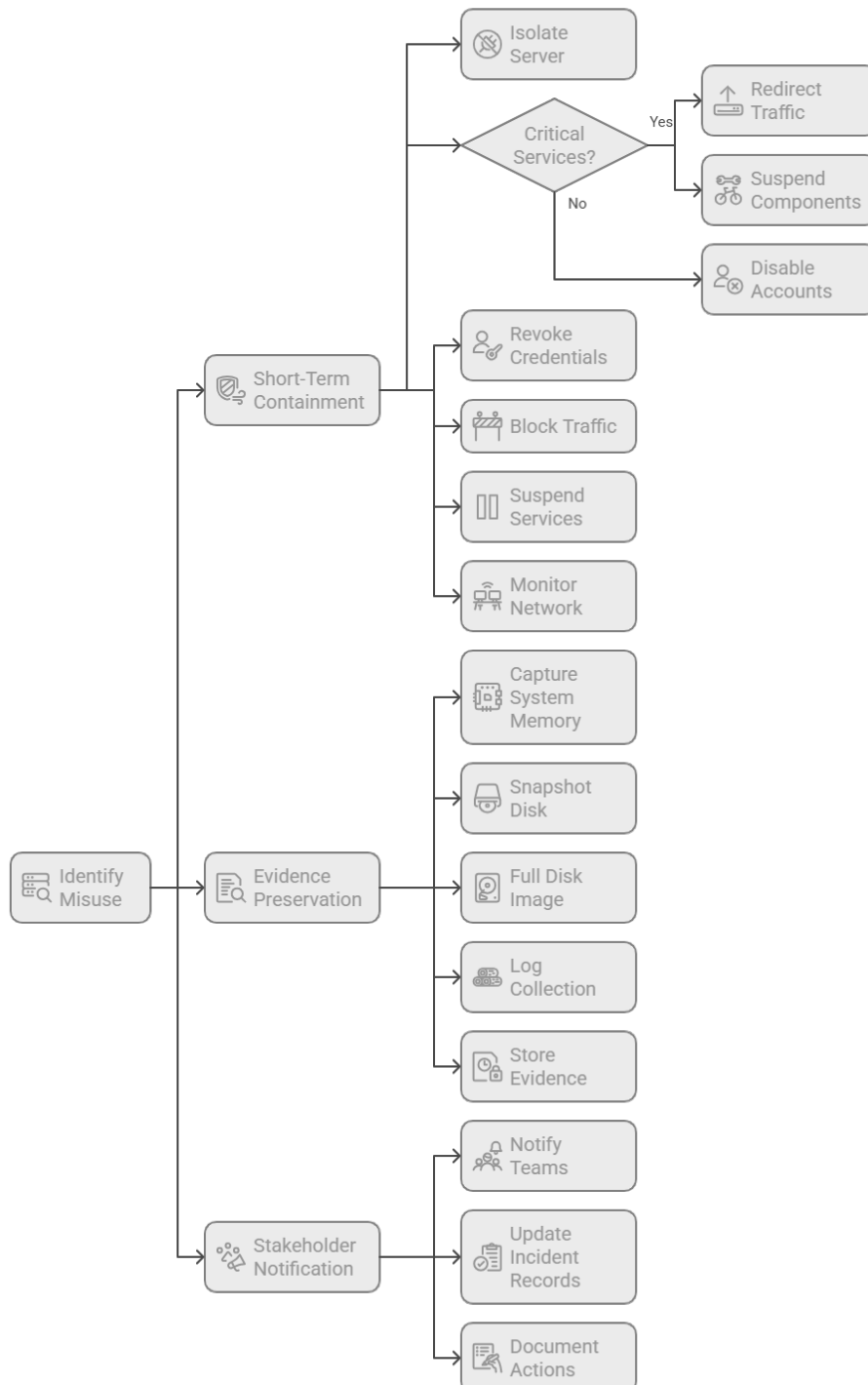


Figure 2: Containment

7 Eradication

The objective of this step is to eliminate the root cause of the misuse and restore the system to a known-good state.

7.1 Identify and Remove the Root Cause

- Identify the attack vector used (e.g., phishing, software vulnerability, stolen credentials).
- Remove malware or unauthorized software from the server.
- Remove any illegal content (e.g. child pornography, unauthorized copyrighted material) from the server. This must be done in coordination with the legal team to ensure legal compliance and proper evidence handling.
- Delete malicious user accounts or keys (e.g., SSH keys) added during the incident.

7.2 Apply Security Fixes

- Patch known vulnerabilities on the system and related services.
- Ensure the latest security updates and anti-malware definitions are applied.
- Reconfigure or disable unnecessary services, open ports, or unused accounts.

7.3 Validate the Environment

- Scan the environment for indicators of compromise (IOCs) to ensure the threat is fully removed.
- Review logs to confirm malicious activity has ceased.
- Confirm with threat intel if the attacker is known for persistence or follow-up attempts.

7.4 Harden the Server

- Enforce the principle of least privilege on access controls.
- Enable multi-factor authentication (MFA) where possible.
- Validate that logging and auditing are enabled and functioning.

Figure 3, visually represents the eradication step.

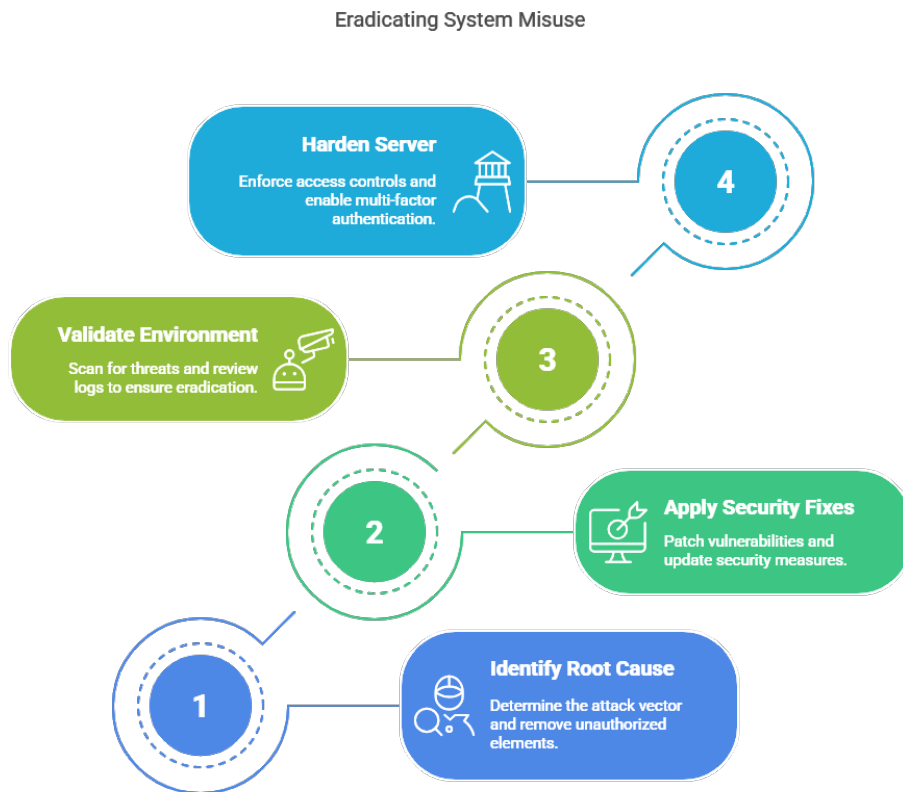


Figure 3: Eradication

8 Recovery

After ensuring that the eradication measures have been effective, the system must be put back into its expected operating mode as soon as possible.

- Check the system's image condition:
 - If the system's image needs a repair:
 - * run the respective system utility (e.g. Deployment Image Servicing and Management (DISM) tool on Windows).
 - If the system's image needs a clean installation:
 - * Check for any available backup images that are prior to the incident and that have not been tampered in any way.
 - * Roll back the system referencing any previously available documentation for good practices during a clean installation/server deployment.
- Check for malware presence by running anti-malware scanning tools.

- Take precautionary measures against the threat surface that made the incident possible (block/retire unsupported technologies).
- Establish stronger monitoring and preventive measures during a specified period of time (one week/month after the recovery operations).
- Test the server operability and functionality to check if everything works as expected.
- Make the server up and running again.
- If everything gets back to the expected operating mode, make a new backup using the current state of the system, together with the improvement that have been made to it.

9 Post-Incident Activities

After every technical operation has been done and the system is once again up and running, it is time to gather valuable insights on the problem.

9.1 Incident report

In order to prevent the same accident from happening twice or more, it is crucial to understand why it happened the first time and what measures have been put in place to tackle it (specifying whether or not a runbook has been followed).

A good baseline for an incident report might look like this[4]:

- description of the incident;
- description of the severity on the incident;
- description of the impact of the incident;
- what is the type of threat or root cause that is likely to have triggered the incident;
- what mitigation measures have been applied and which of them are still ongoing;
- what are the stakeholders involved in this incident.

9.2 Lesson learned

Using the report and the experience gained from the incident happened, it is possible to write a lesson learned document that can be considered as applicable for future improvements and/or should another incident happen. Moreover, it is also used to make future projects more effective and efficient and to promote knowledge transfer within an organization.

A lesson learned document could contain the following information, as a general baseline:

- the information gathered for the incident report of the previous subsection;
- what areas should be reinforced;
- key actions to avoid another incident to happen;
- additional information shared from the people involved in the incident (gathered from interviews, questionnaires and so on).

However, the most important follow-up action of the lesson learned step would be to **share the knowledge** about the incident and its mitigation with other DTU departments.

Keep in mind that an incident can teach more than one lesson and that is reflected on more than one lesson learned document that can be created from that.

9.3 Implementation of new preventive measures

After documenting what has been said in the previous sections, it is necessary to update:

- every system (both those involved in the incident and those not involved) with the new preventive measures;
- the runbook and, eventually, the policies of the department.

10 Conclusion

Now that the end of this document has been reached, the impacted systems and the modus operandi of the attack should have been identified. Ideally, the source of the attack should have been identified as well. This is where the process of forensic investigation starts, if needed.

If another compromised computer has been identified, check for other resources in the DTU Compute department and call the responsible.

Workload Distribution

Breakdown of the workload by team member is shown in Figure 4.

Table 4: Workload Distribution by Section

Team Member	Sections Contributed
Metehan Gelgi (s232839)	1,2,3
Yashasvi Tirpur Vishwanath (s242563)	4,5
Dodzi Kwasi Nuhoho (s240054)	6,7
Stefano Licinio (s232450)	8,9,10

References

- [1] K12 Security Information eXchange (K12 SIX), “K12 SIX Essential Cyber Incident Response Runbook.” <https://www.k12six.org/IR>, June 2022.
- [2] Cybersecurity and Infrastructure Security Agency (CISA), “Cybersecurity Incident and Vulnerability Response Playbooks.” <https://www.cisa.gov/resources-tools/resources/federal-government-cybersecurity-incident-and-vulnerability-response-playbooks>, November 2021.
- [3] A. Nelson, S. Rekhi, M. Souppaya, and K. Scarfone, “Computer Security Incident Handling Guide (NIST SP 800-61 Revision 3).” <https://doi.org/10.6028/NIST.SP.800-61r3>, April 2025.
- [4] Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union (NIS 2 Directive).